

Technical Case Study: Cyber Attack Analysis

Student Name: Itay Rubanenko

Date: 14.06.2026

Chosen Cyber Technique: MitM | Evil Twin

Selected Cyber Attack/Campaign: Evil Twins, Eavesdropping, and Password Cracking: How the Office of Inspector General Successfully Attacked the U.S. Department of the Interior's Wireless Networks

1. Case Overview

- **Attacker / Threat Actor:** Office of Inspector General (OIG) Red Team
- **Victim / Target Organization:** U.S. Department of the Interior (DOI) - Federal Government.
- **Attack Timeline:** June 18, 2018 – June 30, 2019
- **Overall Impact & Damage:** The attackers got the clients of the local network in the federal agency to connect to their evil twin, then they were able to gain access to credentials and abuse weak passwords to gain access to classified information. They even gained access to the IT admin account and were able to analyze internal network architecture and locate internal vulnerabilities.

2. Technical Attack Architecture & Technique Execution

- **Initial Access Vector:** The first step in the evil twin attack was getting physically close to the target network. Then they used low cost (~200\$) equipment to set up the falsive evil twin network.
- **Mechanics of the Chosen Technique:** The attack leveraged fundamental flaws in the 802.11 Wi-Fi protocol that was used in the WPA2 protocol (specifically, the lack of mutual authentication and unprotected management frames) to execute an Evil Twin attack.

a) Exploited Protocols/Vulnerabilities:

802.11 standard roaming mechanisms - the protocol makes the client search for a router with a strong signal strength when physically moving in the space of the network.

Unencrypted Management Frames - general router orders and messages that are not encrypted and can be replicated easily.

Reliance on Pre-Shared Keys (PSK) and one-way EAP authentication sniffing one connection for the .

- b) **Commands/Payloads Used:** The attackers utilized open-source packages (e.g., Aircrack-ng, Hostapd) to broadcast a malicious SSID matching the target "DOI WLAN" but with a stronger transmitting power. They injected spoofed packets matching the legitimate SSID to force client disconnection. Upon forced roaming, the client connected to the Evil Twin, and the attackers captured the encoded credentials (handshakes) for offline password cracking.

Attack Flowchart/Timeline:

Attack Flowchart/Timeline:

1. **January 2018 (Pre-Engagement):** Campaign initialized- OIG issues official Notice of Evaluation regarding the wireless networks.
2. **June 18, 2018 (Initial Intrusion & Reconnaissance):** Field operations begin. Attackers physically deploy to DOI sites and conduct passive Packet Sniffing to identify legitimate SSIDs (e.g., "DOI WLAN") and associated mac addresses.
3. **Mid-2018 to Mid-2019 (MitM Execution Window):**
 - a) Attacker configures the Evil Twin AP using the exact target SSID but broadcasts with a stronger Tx Power (Signal Strength) or faster response time.
 - b) Deauth Injection: Attacker injects spoofed 802.11 Deauthentication frames, forcing legitimate clients to drop their connection to the true AP.
 - c) Forced Roaming & Capture: Clients automatically reconnect to the strongest signal (the Evil Twin). Due to one-way EAP, clients submit their encoded credentials without requiring the AP to prove its identity.
 - d) Offline Cracking: Attackers extract the captured hashes and crack them offline (achieving a 40% success rate independently, and 100% when active downgrade/MitM techniques were combined).
4. **April 30, 2019, 2:07:23 PM (Lateral Movement Confirmed):** Using the cracked credentials of a DOI IT Specialist, attackers successfully bypass the

wireless perimeter, authenticate to the internal ESN, and access the BMC Remedy IT Service Management console (Help Desk). They view their first sensitive internal ticket.

5. **May 7, 2019, 6:19 AM - 10:45 AM (Post-Exploitation & Enumeration):** Attackers maintain persistent internal access, viewing multiple service tickets that expose specific endpoint vulnerabilities, internal network configurations, and deployment failures (e.g., SCCM installation logs).
6. **June 30, 2019 (Conclusion):** Physical testing window closes. Dwell time spans over a year with zero physical detection.

3. Detection Analysis

Analyze the visibility of this attack from an Intrusion Detection System (IDS) perspective.

A. Historical Detection:

Trigger/Telemetry: The physical presence of the attackers went completely undetected by facility security. The Department's Wireless Intrusion Detection System (WIDS) did generate technical alerts for some of the Evil Twin activity.

- **Detection Method:** Detected via signature/anomaly-based WIDS alerts. However, incident responders completely ignored the alerts.
- **Dwell Time:** The attackers maintained undetected operational capability for over 12 months. Responders dismissed the WIDS alerts because they did not physically observe an attacker on-site, rendering the detection useless.

B. Proactive Detection:

- **Signature-Based 44:** WIDS must be configured with hard rules to flag duplicate SSIDs broadcasting from unauthorized MAC addresses, or approved MAC addresses transmitting on unexpected channels.
- **Anomaly Detection:** An advanced WIDS should trigger alerts for sudden 802.11 Deauthentication frames - especially for big batches of these.

4. Key Takeaways & Mitigation

- **Primary Mitigation Strategy:** Mutual Authentication - force both the client to authenticate to the network AND the network to present a valid digital certificate to the client, effectively neutralizing Evil Twins.
- **Lessons for Intrusion Detection:** detection is ineffective without proper reaction. Treating wireless alerts as low-priority "noise" allows attackers to harvest credentials. Detection models must be paired with systems capable of suppressing Evil Twins without waiting for human physical verification.

5. References

- [Reference 1: U.S. Department of the Interior, Office of Inspector General, "Evil Twins, Eavesdropping, and Password Cracking: How the Office of Inspector General Successfully Attacked the U.S. Department of the Interior's Wireless Networks," Report No. 2018-ITA-020, September 2020]
<https://www.govinfo.gov/content/pkg/GOVPUB-I-PURL-gpo214561/pdf/GOVPUB-I-PURL-gpo214561.pdf>
- [Reference 2: MITRE ATT&CK, "Adversary-in-the-Middle," Technique T1557,
<https://attack.mitre.org/techniques/T1557/>]
- [Reference 3: MITRE ATT&CK, "Network Sniffing," Technique T1040,
<https://attack.mitre.org/techniques/T1040/>]